

1. 업무개요

수도권동부환경본부(◆◆◆◆◆◆◆◆처 -----부, 이하 “-----부”라 한다)는 「자원의 절약과 재활용 촉진에 관한 법률」 제9조(포장폐기물의 발생억제)에 의거하여 포장 폐기물 발생 억제와 재활용 촉진을 위해 제품을 제조·수입 또는 판매하는 자가 재활용이 쉬운 포장재를 사용하고, 불필요한 포장을 억제하도록 포장재질과 포장방법에 관해 검사하고 있다.

[표 1] 포장검사 종류

구분	내용
포장재질	분리배출 표시를 위한 포장재의 재질검사 및 폴리비닐클로라이드(PVC) 사용 여부 검사
포장방법	음식료품류 등 8개 제품군 32개 품목에 대해 포장공간비율 및 포장횟수 기준 준수 여부 검사

그리고, 자원순환본부(☞☞☞처, 이하 “☞☞☞처”라 한다)는 포장재질·포장방법 검사 신청을 온라인에서 바로 등록하고, 진행 상태를 확인하며, 성적서를 조회할 수 있도록 -----시스템(시스템, 이하 “시스템”이라 한다) 누리집(-----.-.-.-)을 운영하고 있다.

[그림 1] 누리집 및 관리자 화면

<생략>	
누리집	관리자(신청업체현황)

2. 관련규정 및 판단기준

개인정보 보호법 제29조(안전조치의무)에서 개인정보처리자는 개인정보가 분실·도난·유출·위조·변조 또는 훼손되지 아니하도록 내부 관리계획 수립, 접속기록 보관 등 대통령령으로 정하는 바에 따라 안전성 확보에 필요한 기술적·관리적 및 물리적 조치를 하여야 한다고 되어있다.

그리고, 공단 「정보보안 업무지침」 제77조(비밀번호 관리) 제1항에는 정보시스템 사용자 보안을 위해 개별사용자 및 공용(公用) 정보시스템 관리자는 각종 비밀번호에 [표 2]에 해당하는 사항을 반영하고, 숫자·대/소문자·특수문자 등을 혼합하여 9글자 이상 안전하게 설정하여 정기적으로 변경·사용하도록 하고 있다.

[표 2] 비밀번호 설정 시 반영 필요 사항

구분	내용
1	사용자 계정(아이디)과 동일하지 않은 것
2	개인 신상 및 부서 명칭 등과 관계가 없는 것
3	일반 사전에 등록된 단어의 사용을 피할 것
4	동일한 단어 또는 숫자를 반복하여 사용하지 말 것
4-1	연속한 단어 또는 숫자를 사용하지 말 것
5	사용된 비밀번호는 재사용하지 말 것
6	동일한 비밀번호를 여러 사람이 공유하여 사용하지 말 것
7	응용프로그램 등을 이용한 자동 비밀번호 입력기능을 사용하지 말 것

또한, 같은 지침 제76조(계정 관리) 제1항에는 개별사용자에게 소관 정보통신망 또는 공용(公用) 정보시스템의 접속에 필요한 사용자 계정(아이디)을 부여하고자 할 경우 개별사용자별 또는 그룹별 접근권한을 부여하도록 하고 있다.

3. 감사결과 확인된 문제점

금번 종합감사 기간에 -----부에서 사용하고 있는 시스템의 비밀번호 안전성을 확인한 결과, 사용자 비밀번호를 영문, 숫자, 특수문자가 포함된 9자리 이상으로 설정하도록 운영하고 있었으나, 비밀번호 설정 시 반영이 필요한 내용 중 일부분이 반영되어 있지 않음을 확인하였다.

사용자가 시스템 비밀번호 설정 시 ID를 이용하거나, 일반 사전에 등록된 단어를 사용하는 것이 가능하였다. 또한, 특정 패턴(동일한 문자를 반복하거나 키보드 상에서 연속한 위치에 존재하는 문자들을 입력)을 갖는 비밀번호로 설정하는 것이 가능하였고, 기존 사용하였던 비밀번호를 재사용하여 변경하는 것에도 별도 제한이 없었다.

[표 3] 비밀번호 설정 시 미반영 사항

구분		예시
사용자 ID를 이용한 비밀번호		ID가 'KECRec'인 경우, 'KECRec12!'로 설정
일반 사전에 등록된 단어 사용		dictionary1!
특정 패턴을 갖는 비밀번호	동일한 문자의 반복	aaabbbccc1!, 123123123a!
	키보드 상에서 연속한 위치에 존재하는 문자들의 집합	qwertyu1!
사용된 비밀번호 재사용		-

그리고, 임시비밀번호 찾기 기능은 사용자가 비밀번호 분실 등의 이유로 사용하기 위해서 제공되고 있고, 사용자가 회원가입 시 등록한 이메일주소로 임시비밀번호를 발송하도록 운영되고 있다. 그러나, 이메일로 발송된 임시비밀번호는 영문·숫자의 2가지 유형이 혼합된 6자리로 설정·운영하고 있었으며, 사용자가 임시비밀번호를 통해 시스템에 로그인한 후 안전한 비밀번호로 변경하지 않아도

기존 임시비밀번호를 통해 시스템을 사용할 수 있는 등 비밀번호 관리가 미흡하였다.

또한, -----부 담당자 권한으로 공단 전체 포장검사 결과의 처리 내용을 확인하고 수정할 수 있었으며, 시스템 회원 정보에 대해서도 제한없이 조회 및 수정이 가능하도록 설정되어 있는 등 환경본부 담당자의 시스템 접근권한이 업무상 필요한 최소한으로 정의되어 있지 않은 상태로 운영되고 있는 것을 확인하였다.

[그림 2] 환경본부 담당자 화면

<생략>	
검사처리결과	회원 목록

따라서, -----처는 시스템 비밀번호를 지침에 맞도록 안전하게 설정해서 운영하도록 하고, 환경본부 담당자의 시스템 접근 권한을 조정하여 개인정보 및 시스템의 안전성을 확보할 필요가 있다.

4. 조치할 사항

자원순환이사(-----처장)는 -----시스템의 사용자 보안 및 접근권한 취약점 개선을 하기 위한 방안을 마련하시기 바랍니다. 【시정(기타)】